

Prioritization: CVSS, EPSS & CISA KEV

The CVSS Trap

CVSS 3.x base = intrinsic severity, computed by math on properties.
BUT:

A CVSS 9 in an air-gapped lab $\neq$ high risk

A CVSS 5 with a 5-year-old public exploit (EternalBlue!) is **more dangerous** than a newer CVSS 9 without a working exploit

CVSS tells you how *severe* a vulnerability might be, not how *likely it is to be exploited in YOUR estate now*. Two different curves.

EPSS: Probability, Not Severity

EPSS (Exploit Prediction Scoring System) estimates the **probability a CVE will be exploited in the wild in the next 30 days** with a model trained on real exploit data.

```
# EPSS API (free):  
curl https://api.first.org/data/v1/epss?cve=CVE-2023-23397  
# → score: 0.67 = 'top 4% most-likely-to-be-exploited CVEs'
```

How to combine: **CVSS + EPSS:**

High CVSS + high EPSS = **your top queue**

Low CVSS + high EPSS = "cheap to avoid being on the horror list", fix anyway

High CVSS + negligible EPSS = priority drops unless you're a juicy target

CISA KEV: "Being Exploited in the Wild – NOW"

Known Exploited Vulnerabilities (KEV) catalog – CVEs with confirmed public exploitation. If it's on KEV, it's real, now:

```
# CISA KEV catalog (JSON, free)
curl https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
# filter latest 20 by dateAdded and vendor
```

The automotive golden rule of modern VM:

Vulnerabilities with known public exploits ("in the wild") get fixed FIRST, no debate, regardless of CVSS number.

Prioritize With RICH CONTEXT

The perfect question = "what will hurt me most, soonest?":

Is it exploited in the wild? (KEV / EPSS high)

Is it exposed? (internet-facing? reachable?)

Is the asset critical? (crown jewel)

Do we have a compensating control? (e.g. WAF in front of the vulnerable web app)

What's the fix cost (reboot? downtime? tooling)?

The "Exposure" Reducer

Internet-facing + KEV = fix by the weekend

Internal only + EPSS low = schedule in sprint (careful: still fix!)

Segmented so blast radius small = lower urgency but track

The discipline: everything gets a ticket, nothing lives forever unpatched. But the ORDER is driven by what's *actually happening in the world*, not a desk-award CVSS figure.

[← The Vulnerability Management...](#)

[Vulnerability Management in th...](#)